Cybersecurity Incident Report

APEX Tech Forge Academy - Cybersecurity Program Capstone

Prepared by: Edward Jose Maria, Junior Security Analyst **Date:** 31 October 2026

Phase 1: Threat Assessment & Policy (Executive Summary)

To: Academy Leadership **From:** Edward Jose Maria, Security Lead
Subject: Urgent Security Upgrade: Protecting Student Records and Academy Operations

Why this upgrade is critical

APEX Tech Forge Academy has recently detected a rise in phishing attempts and unauthorised network scanning. Scanning is usually the first stage of an attack, where an attacker looks for open doors before trying to break in. The Academy holds student records, personal details, and payment and academic information, and a breach would harm students directly. It would also damage the Academy's reputation, cause students and partners to lose trust, and could bring legal and financial consequences. For an academy that teaches cybersecurity, a public breach would be especially damaging. Acting now is far cheaper than recovering after an incident, and it protects the Academy's credibility and continued operation.

How the CIA Triad protects student records

Principle	What it means	How it will be applied
Confidentiality	Only authorised people can see the data	Encrypted remote access (SSH), strong passwords, and file permissions that limit sensitive records to their owner
Integrity	Data is accurate and has not been altered	Cryptographic hashing (SHA-256) to detect tampering with records and backups
Availability	Data and systems are accessible when needed	A firewall that allows only required services, regular backups, and continuous monitoring

Three realistic threats and recommended mitigations

1. Phishing. Attackers send deceptive emails to steal staff or student credentials. *Mitigation:* run regular security-awareness training with simulated phishing exercises, and enable multi-factor authentication (MFA) on all accounts so stolen passwords alone are not enough.

2. Ransomware. Malware encrypts Academy files and demands payment to restore them. *Mitigation:* keep regular, tested offline backups of critical data and verify their integrity with hashing, so the Academy can recover without paying.

3. Unauthorised network scanning and brute-force attacks. Attackers probe servers for open ports and repeatedly guess passwords to gain access. *Mitigation:* configure a firewall (UFW) to expose only the necessary service (SSH on port 22), use encrypted remote access, and monitor authentication logs so repeated failed logins are detected early.

Recommendation

Leadership should approve immediate implementation of these controls on the Academy's primary servers. The technical steps and evidence are documented in the following phases of this report.

Phase 2: Secure Remote Administration

Objective: manage the Academy's Linux server remotely over an encrypted tunnel instead of sending credentials in plaintext.

Environment: Windows host (PuTTY, Nmap, Wireshark) and an Ubuntu Linux server running in VMware Workstation (IP 192.168.154.131). OpenSSH was installed and enabled, and the Uncomplicated Firewall (UFW) was configured with a default-deny policy for incoming traffic and a single rule allowing port 22.

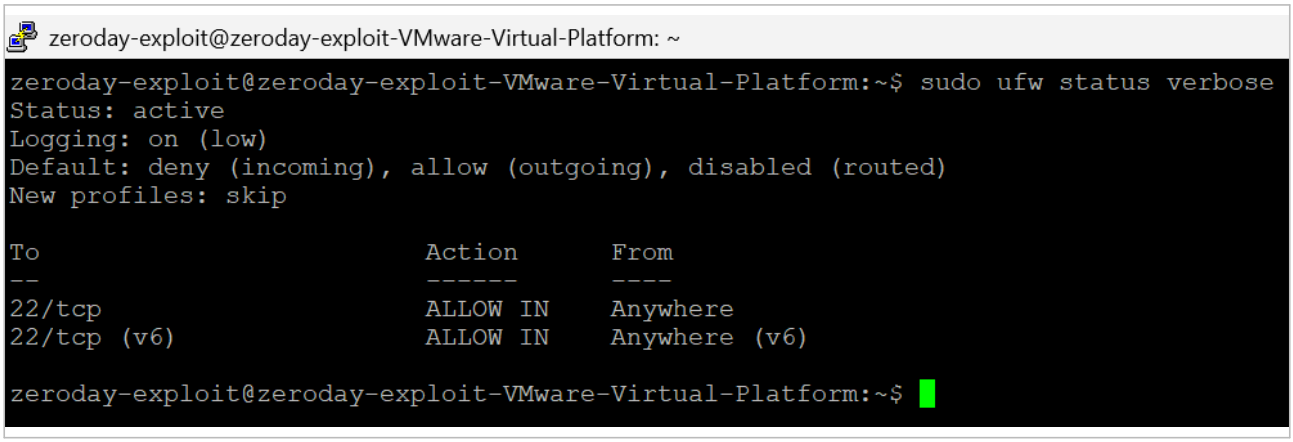


Figure 1 - UFW status. The firewall is active, incoming traffic is denied by default, and only 22/tcp (SSH) is allowed, for both IPv4 and IPv6.

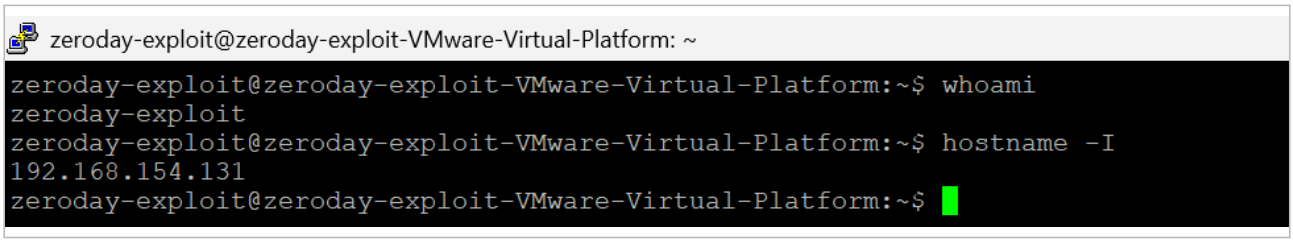


Figure 2 - A successful PuTTY session from the Windows host to the Linux server over SSH. The user is zeroday-exploit and the server address is 192.168.154.131.

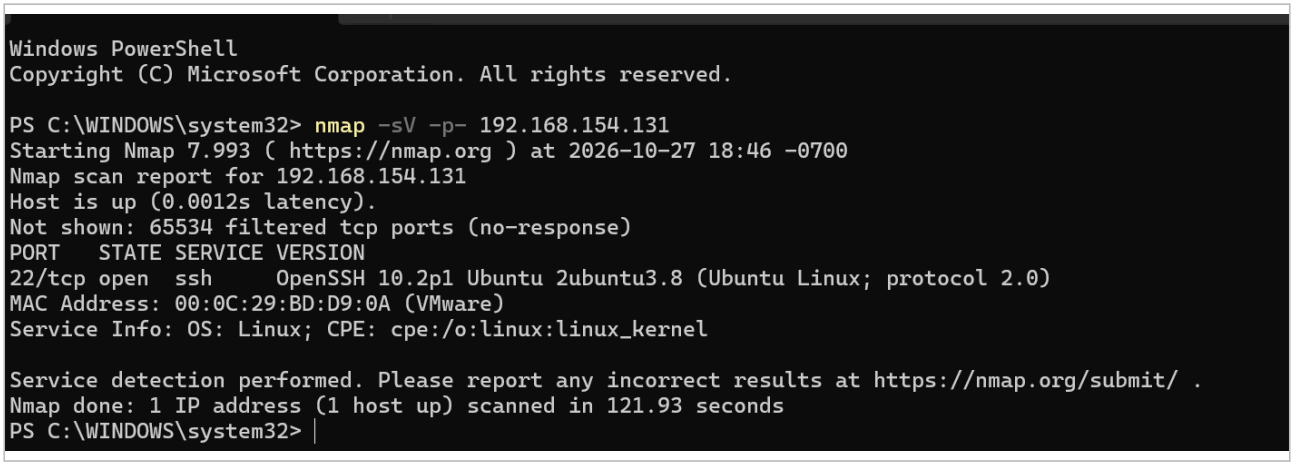


Figure 3 - Nmap scan of all 65,535 ports on the server (nmap -sV -p- 192.168.154.131). Port 22/tcp (SSH) is the only open port; the other 65,534 ports are filtered. This confirms the UFW configuration is working.

Phase 3: Data Integrity Verification

Objective: use cryptography to prove a file's integrity, and restrict access to a sensitive records file.

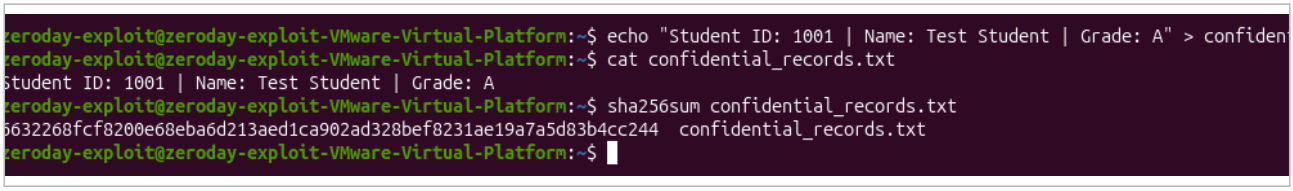


Figure 4 - Creation of confidential_records.txt, display of its contents, and its SHA-256 hash generated with sha256sum. The hash is the file's fingerprint in its original, trusted state.

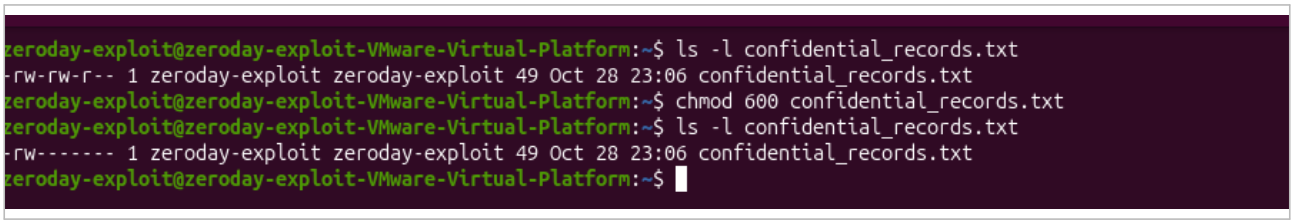


Figure 5 - File permissions before and after. Before: -rw-rw-r-- (group members could read and write). After chmod 600: -rw------- (only the owner can read and write).

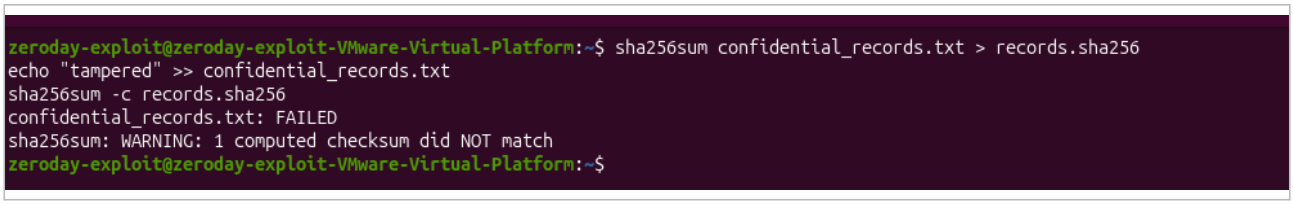


Figure 6 (bonus) - Tamper detection. After the file was deliberately modified, sha256sum -c reports FAILED because the new hash no longer matches the original. The modification was made after Figure 4, so the file's current hash differs from the one shown there.

Why hashing is vital for incident response

Hashing creates a unique digital fingerprint of a file, so changing even one character produces a completely different hash. During incident response, comparing a file's current hash with a known-good hash quickly shows whether malware or an attacker has tampered with it, and which backups can still be trusted.

Phase 4: Network Monitoring & Validation

Objective: verify that the security controls work by capturing live traffic, triggering failed logins, and locating the log entries that recorded them.

The firewall as a network choke point

A firewall sits at the single point where traffic enters a system, so every connection has to pass through it and be checked against its rules. On this server, UFW denies all incoming traffic by default and allows only port 22, so a connection to any other port is dropped before it can reach a service. Because all traffic funnels through one place, it can be controlled, inspected and logged from one spot, without securing every service individually.

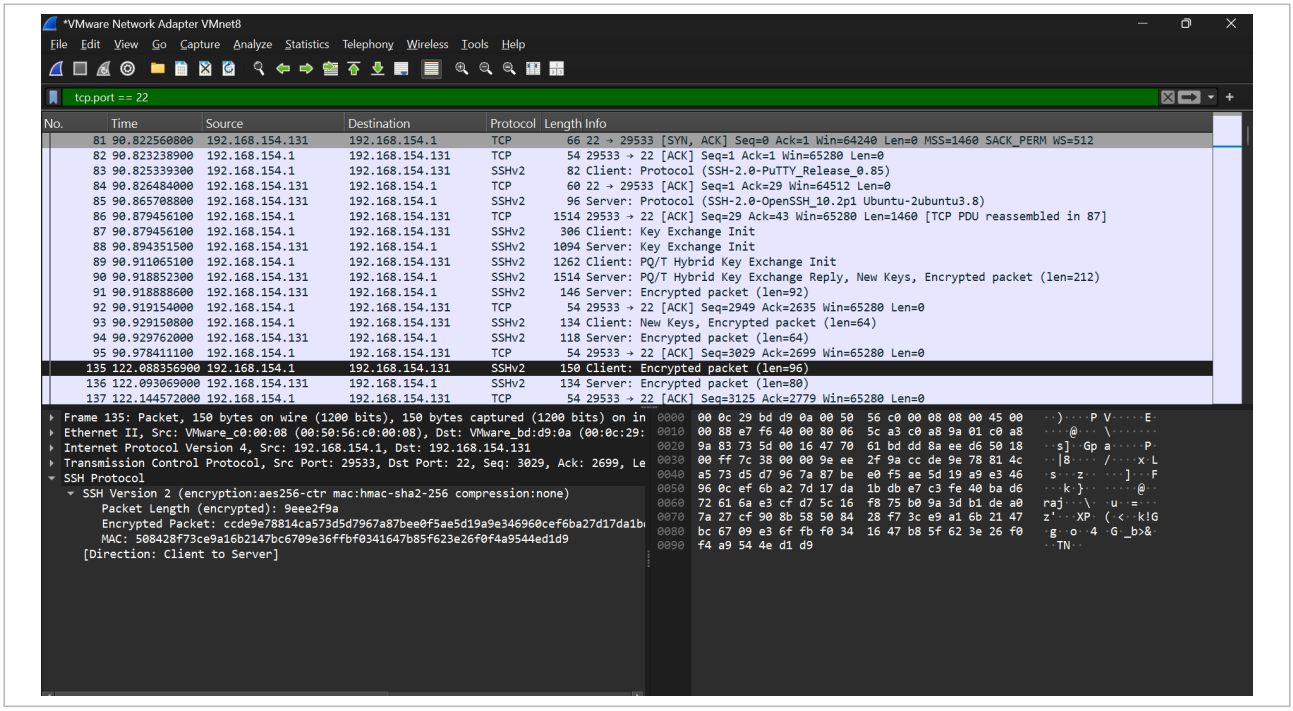


Figure 7 - Wireshark capture of the active SSH session (filter tcp.port == 22). After the handshake and key exchange, the traffic appears only as "Encrypted packet", protected with aes256-ctr encryption and hmac-sha2-256 integrity checking.

Why this is secure compared to HTTP or Telnet: everything after the key exchange is encrypted, so someone capturing this traffic cannot read the username, password or commands. Only the version banners are visible, and they contain no credentials. A capture of HTTP or Telnet would show usernames, passwords and every command as plain readable text that an attacker on the network could read directly.

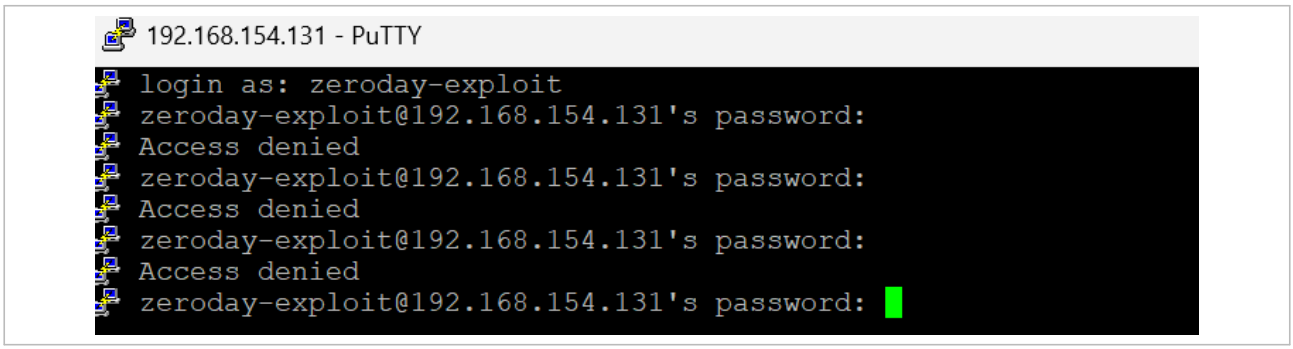


Figure 8 - Three login attempts using a deliberately wrong password. Each one was rejected with "Access denied".

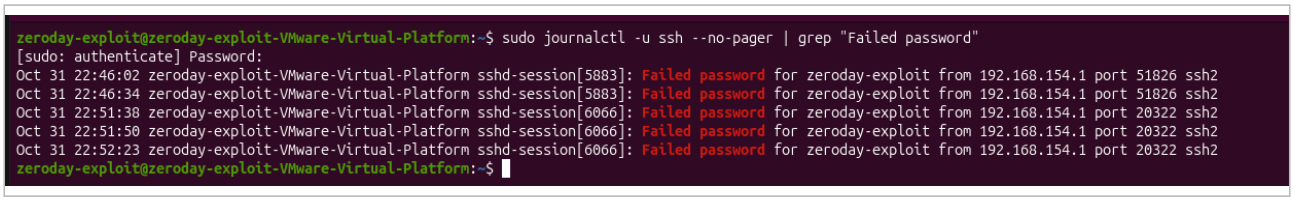


Figure 9 - The server's SSH log (sudo journalctl -u ssh | grep "Failed password") records each failed attempt with the timestamp, the targeted account (zeroday-exploit), the source address (192.168.154.1) and the source port.

Why monitoring this log is critical for detecting brute-force attacks: a brute-force attack appears as many failed logins for one or more accounts in a short time, often from the same source address. Watching this log lets an analyst spot the pattern early, block the source, and respond before the attacker guesses a valid password.

Conclusion

The firewall limits the server's exposure to a single service, SSH encrypts remote administration, hashing and permissions protect the integrity and confidentiality of sensitive records, and log monitoring exposes attack attempts. Together these controls apply all three parts of the CIA Triad and give the Academy a practical defence against the threats identified in Phase 1.

Project documentation and commands: github.com/kcyberEd/apex-cybersecurity-capstone